

SecurityGroup101 — Vendor Risk Management POA&M (Plan of Action and Milestones)

NIST SP 800-53 Rev. 5 CA-5 (Plan of Action and Milestones) · NIST SP 800-161 Rev. 1 Upd. 1 GV.SC-09 · NIST CSF 2.0 ID.RA, RS.MI · PCI DSS v4.0 Req 12.8 · GLBA Safeguards Rule

Last Updated: July 2026 · Maintained by: Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu · Review cadence: Monthly

SUMMARY: 8 open findings — 1 High (Snowflake DSP-01: PII data masking not implemented), 2 Medium (Zendesk VRM-2026-005: DPA subprocessor update; GitHub VRM-2026-006: GHAS secret scanning cadence), 3 Low, 2 Informational. No critical findings. All findings have assigned owners and documented due dates. Next monthly review: August 2026.

Finding ID	Vendor	Finding Description	CCM ID	Severity	Finding Owner	Due Date	Status	Evidence Required	Analyst Notes
VRM-2026-001	Stripe	Third-party data sharing register not completed. Stripe discloses third-party sharing in its privacy notice but has not provided a comprehensive data flow register documenting all downstream data sharing arrangements.	DSP-09	Low	Stripe Security / SG101 Vendor Mgr	Q4 2026	Open	Written confirmation from Stripe that data sharing register is complete and available for SG101 review. Updated CAIQ DSP-09 response submitted.	Identified Jul 2026 CAIQ review. Stripe acknowledged gap 07/15/2026 and committed to Q4 2026. Tracked in monthly vendor touchpoint.
VRM-2026-002	Stripe	Supply chain risks not yet formalized as discrete items in Stripe's risk register. AWS and Google Cloud dependency risks identified in gap analyses but not in Stripe's formal risk register.	STA-06	Info	Stripe GRC / SG101 Vendor Mgr	Q4 2026	In Progress	Stripe risk register excerpt or written attestation confirming supply chain risks formally documented as discrete items. Updated STA-06 response.	Stripe confirmed internal roadmap item (Q3 2026 target). SG101 monitoring. Not blocking approval given 92% CAIQ score and strong overall posture.

Finding ID	Vendor	Finding Description	CCM ID	Severity	Finding Owner	Due Date	Status	Evidence Required	Analyst Notes
VRM-2026-003	AWS	Automatic KMS key rotation — confirm enabled for all SG101 Customer Managed Keys (CMKs), not only AWS-managed keys. Identified during internal control testing July 2026.	CEK-05	Low	SG101 Engineering	Aug 2026	Open	AWS CloudTrail evidence showing automatic rotation enabled for all CMKs. KMS console screenshot. Internal audit record.	SG101 owns this remediation (AWS configuration task). Engineering team assigned Jul 2026. Due Aug 31 2026.
VRM-2026-004	Datadog	Current-period SOC 2 Type II report not yet obtained. Previous review covered period ended March 2025. Current audit period ended March 2026 — report now available on Datadog trust portal.	LOG-04	Info	SG101 Vendor Manager	Aug 2026	Open	Current SOC 2 Type II report (period ended March 2026) obtained from Datadog trust portal, reviewed, and filed with no qualified findings.	Annual refresh item. Vendor Manager to download and review by Aug 15 2026.
VRM-2026-005	Zendesk	Zendesk DPA not updated to reflect Q1 2026 subprocessor addition (Anthropic AI for customer support summarization). 30-day notice window passed without DPA amendment. Medium severity.	STA-05	Medium	SG101 Legal / Vendor Mgr	Sep 2026	Open	Updated DPA signed by both parties, reflecting current subprocessor list. Written confirmation AI summaries do not include SG101 customer PII.	Zendesk notified SG101 04/12/2026. Escalated to Legal 07/01/2026. DPA amendment required before continued use of AI summarization feature.
VRM-2026-006	GitHub	GitHub Advanced Security (GHAS) secret scanning alerts not reviewed on defined cadence. Backlog of ~14 alerts identified (primarily test credentials — none in production).	TVM-01	Medium	SG101 Eng / Security	Sep 2026	In Progress	GHAS dashboard screenshot showing zero open high/critical alerts OR documented review process with evidence of most recent review cycle.	Engineering alerted 06/20/2026. Backlog triage in progress. Alert review process documentation required by Sep 2026.

Finding ID	Vendor	Finding Description	CCM ID	Severity	Finding Owner	Due Date	Status	Evidence Required	Analyst Notes
VRM-2026-007	Okta	Okta Privileged Access (OPA) module license procured May 2026 but not yet activated. Admin account management currently uses standard Okta admin console without dedicated PAM controls.	IAM-06	Low	SG101 IT / Security	Oct 2026	Open	OPA module activated; admin roles migrated to OPA with JIT access and session recording enabled. Configuration export and access test evidence.	OPA activation deprioritized. Flagged in quarterly access review Jul 2026. Oct 2026 target. Low risk — standard console logging is active.
VRM-2026-008	Snowflake	Snowflake Dynamic Data Masking policies not yet implemented for PII columns in the analytics environment. PII visible to all BI team members regardless of data classification tier. HIGH severity.	DSP-01	High	SG101 Data Eng / Security	Aug 2026	In Progress	Data masking policies applied to all PII columns per data classification policy. Access test results showing masked output for non-privileged users. Policy config export.	HIGH severity — PII exposure risk. Data classification policy updated May 2026 to classify these fields as Restricted. Engineering design complete; implementation Aug 2026. Weekly tracking by Security team.